

Auditoria na Prática

Projecto de Auditoria de Segurança de TI

Por definição, podemos dizer que um projeto é algo único, exclusivo e temporário que possui começo, meio e fim e que deve ser gerenciado e monitorado. Bem, um projeto de auditoria de segurança de TI, possui a mesma definição sobre projeto, porém seu escopo está relacionado à área da segurança da informação ou segurança cibernética.

Um projeto de auditoria de segurança de TI não é algo fácil de ser realizado e concluído, muito pelo contrário, trata-se de um projeto complexo que irá durante as fases de planejamento e execução abranger todos os aspectos relacionados à segurança da informação e segurança cibernética, além de questões relacionadas a gerenciamento, gestão, políticas, normas e procedimentos adotados por parte da organização para garantir a proteção de seus ativos de TI.

Além do mencionado anteriormente, um projeto de auditoria da segurança de TI deve considerar no seu escopo: (a) a arquitetura e design da segurança da informação e segurança cibernética; (b) os sistemas de rede e telecomunicações; (c) os sistemas de autenticação e autorização de acessos físicos e lógicos a usuários; (d) os planos de continuidade de negócio; (e) os planos de continuidade de TI; (f) os planos de contingência de TI. (g) os planos de recuperação de desastre; (h) a gestão de risco e compliance da área de TI e, demais outros aspectos que a própria auditoria julgar necessária em relação o modelo de negócio da organização.

Como práticas para a elaboração de um projeto de auditoria de segurança de TI, apresentamos:

a) **Reunião de Kick-Off** – momento em que o auditor irá conduzir uma reunião com a alta administração da organização, para realizar um brainstorming que terá como objetivo fomentar todas as necessidades e expectativas da alta administração com relação a auditoria que será realizada;

b) **Planejamento** – momento em que o auditor coloca no papel tudo aquilo que será realizado durante a auditoria. Ou seja, é o momento em que o auditor irá construir o escopo do projeto de auditoria, baseando-se em diversos fatores tais como: (a) objetivo da auditoria; (b) itens envolvidos durante o processo de exame e avaliação realizado pela auditoria; © necessidades e expectativas das partes interessadas; (d) premissas e restrições; (e) tempo de execução da auditoria; (f) mecanismos de controle e check point da auditoria; (g) custo (para auditorias externas) da auditoria; (h) fatores críticos de TI a serem auditados; (i) mecanismos de avaliação; (j) formato dos resultados (não conformidade) encontrados; (l) modelos de entrega de evidências; (m) recursos necessários à realização da auditoria; e demais itens que julgar necessários a realização da auditoria;

c) **Execução** – momento em que o auditor realiza a auditoria, ou seja, momento em que o auditor realiza os processos relacionados ao exame e avaliação dos ativos de TI, incluindo políticas, planos, normas, controles, procedimentos e mecanismos de segurança da informação e segurança cibernética. Em geral, a fase de execução é uma fase que requer uma atenção redobrada do auditor, devido ao fato de que ele irá realizar o exame e a avaliação de uma série de documentos, procedimentos e mecanismos de proteção. Costuma-se dizer que é a fase em que o auditor está em “campo” realizando todo o trabalho de auditoria.

d) **Monitoramento/Controle** – é o momento em que o auditor estabelece os “checkpoints” de auditoria, para que possa verificar o relacionamento entre o que foi planejado na fase do escopo e o que está sendo executado na fase de execução da auditoria. Nesta fase, caso o auditor precise reconsiderar, ajustar ou corrigir o escopo da auditoria, ele o fará durante o monitoramento e controle.

e) **Relatório Final** – é o momento em que o auditor irá apresentar no formato de relatório, todo o trabalho realizado durante a auditoria, incluindo: (a) as não conformidades encontradas; (b) as evidências que comprovam as não conformidades apresentadas; © as bases legais de acordo com as leis e regulamentações que validam as não conformidades; (e) as sugestões de correção, conforme leis, regulamentações, políticas, normas, regras e frameworks de melhores práticas; (f) os riscos que a organização está sujeita perante a não tratativa das não conformidades encontradas; (g) a classificação dos riscos encontrados e demais itens que o auditor julgar necessário acrescentar no relatório;

f) Respostas a Não conformidade – é o momento em que a organização fornece as devidas respostas em relação à concordância ou não das não conformidades encontradas, bem como as ações que serão tomadas para corrigir as não conformidades e o tempo em que serão executadas e concluídas.

Dicas para a criação de um Projeto de Auditoria de Segurança de TI

Aqui exponho algumas dicas que são consideradas úteis para a criação e execução de um projeto de auditoria:

(a) mapeie todos os objetos que deverão ser auditados; (b) escolha uma metodologia de auditoria de acordo com o perfil, modelo de negócio e operações da organização. É importante ressaltar que existem diversas metodologias que um auditor pode seguir com base no perfil da organização. Por exemplo, supondo que a organização é uma empresa de desenvolvimento de softwares voltados para o uso no ambiente da internet, o auditor pode seguir as metodologias proposta pela fundação OWASP que é uma fundação totalmente open source (sem fins lucrativos e aberta a todos) que promove, orienta, especifica e promove debates e discussões sobre o desenvolvimento seguro de sistemas, aplicativos e aplicações totalmente voltadas para a internet. Ou seja, o desenvolvimento de padrões de segurança para qualquer tipo de sistema ou aplicativo/aplicação que tem como princípio ser executada na internet, formada por diversas empresas (de diversos segmentos e porte) especializadas em proteção cibernética, bem como: pesquisadores, cientistas, estudiosos, desenvolvedores, analistas de segurança e quaisquer entusiastas do tema, promovendo debates, criando padrões e melhores práticas a serem seguidas; © escolha as ferramentas que serão utilizadas durante a auditoria e de acordo com o escopo e o(s) objeto(s) a serem examinados e avaliados durante o processo de auditoria; (d) documente tudo que encontrar – aqui o auditor deverá documentar/evidenciar todo que for sendo examinado e avaliado durante a auditoria. Essa documentação servirá como matéria-prima para a entrega do relatório final de auditoria; (e) crie pontos de checagem e verificação de todo o trabalho já realizado, incluindo uma lista de solicitações já atendidas para verificar e validar o que já foi examinado em relação do que ainda não foi.

Lembre-se que inicialmente a auditoria será um projeto. Mas, posteriormente a auditoria deverá ser vista como um processo trimestral, semestral ou anual de exame e avaliação da TI e de tudo que pertence a mesma com relação a operacionalização,

segurança, integridade, disponibilidade, processos críticos e não críticos, autenticidade e autorização, dentre outros itens.

Por fim, é importante dizer que tanto o projeto, quanto o processo de auditoria serão diferentes de empresa para empresa. Isto porque, cada empresa possui sua própria infraestrutura de TI, suas particularidades baseadas no modelo de negócio, porte ou tamanho da empresa, suas políticas, normas, regras e procedimentos internos e, leis e regulamentações impostas por órgãos reguladores. São esses aspectos que tornam cada auditoria única e diferente uma da outra.

Conteúdo Bônus

Para saber mais sobre segurança e auditoria em sistemas de informação, sugiro as seguintes leituras:

LYRA, Mauricio Rocha. **Segurança e Auditoria em Sistemas de Informação**, 2ª Ed. – Ciência Moderna – 2017.

GIL, Antônio de Loureiro. ARIMA, **Carlos Hideo. Auditoria do negócio com TI: Gestão e operação**. 1ªEd. Saraiva, 2018.

Referência Bibliográfica

FONTES, E. **Praticando a segurança da informação**. – 2ªEd. Rio de Janeiro. Brasport, 2008.

HARRIS, Shon. **CISSP All-in-one, 3. ed.** Nova York, McGraw Hill, 2004.

KIM, David; SOLOMON, Michael. **Fundamentos de Segurança de Sistemas de Informação – 1.ed.** São Paulo; LTC Exatas Didática, 2014.

LYRA, M. R. **Segurança e Auditoria em Sistemas de Informação**. Rio de Janeiro: Ciência Moderna, 2008.

MACHADO, Felipe R. Nery. **Segurança da Informação – Princípios e controle de ameaças – 1.ed.** Rio de Janeiro; Editora Érica, 2014.

SÊMOLA, M. **Gestão da Segurança da Informação - Uma Visão Executiva - 2 ed.** São Paulo: Elsevier, 2014.

STALLINGS, Willian; BROWN Lawrie. **Segurança de Computadores – Princípios e Práticas. 2.ed.** São Paulo; Elsevier, 2017.

ASSI, Marcos. **Governança, Risco e Compliance: Mudando a conduta nos negócios** – Edição Padrão, São Paulo Saint Paut, 2017.

FERNANDES, Aguinaldo Aragon. ABREU, Vladimir Ferraz. **Implementando a Governança de TI: da estratégia à gestão dos processos e serviços – 4ª Ed.** Brasport – Rio de Janeiro 2014.